

GUIA PASO A PASO PARA CREAR UN PLAN DE CONTINGENCIA

1. Definir los objetivos y el alcance del plan

- **Objetivos:** ¿Qué esperas lograr con el plan? Generalmente, se busca proteger a la empresa, las personas y los activos ante situaciones de crisis.
- **Alcance:** ¿Qué áreas o procesos están cubiertos por el plan? Esto puede incluir sistemas informáticos, recursos humanos, cadena de suministro, etc.

2. Identificar los riesgos y las amenazas

- **Análisis de riesgos:** Realiza un análisis detallado de los posibles riesgos que podrían afectar tu organización. Algunos ejemplos incluyen desastres naturales (terremotos, inundaciones), fallos tecnológicos, fallas en la cadena de suministro, ciberataques, pandemias, etc.
- **Probabilidad e impacto:** Evalúa la probabilidad de que cada riesgo ocurra y el impacto potencial en la organización. Esto ayudará a priorizar las amenazas más críticas.

3. Desarrollar estrategias de respuesta

- **Prevención:** ¿Qué acciones puedes tomar para evitar que ocurran ciertos riesgos o minimizar su impacto? Esto podría incluir la implementación de medidas de seguridad, capacitación del personal o inversión en tecnología.
- **Mitigación:** ¿Cómo puedes reducir los efectos de un incidente cuando ocurra? Esto podría involucrar tener sistemas de respaldo, cambiar a proveedores alternativos, etc.
- **Recuperación:** ¿Cómo vas a recuperar las operaciones tras un evento? Esto puede incluir planes para restaurar sistemas de TI, rehabilitar las instalaciones, reorganizar equipos de trabajo, etc.

4. Designar roles y responsabilidades

- **Equipos de contingencia:** Asigna a las personas clave dentro de la organización para que lideren el plan en caso de una crisis. Asegúrate de que cada miembro del equipo sepa cuál es su rol y qué debe hacer en una emergencia.
- **Responsabilidades claras:** Define con claridad quién se encargará de cada área (finanzas, operaciones, comunicaciones, etc.) durante la contingencia.

5. Establecer procedimientos detallados

- **Pasos a seguir en caso de emergencia:** Elabora un conjunto claro de procedimientos para cada tipo de emergencia identificada. Esto puede incluir instrucciones para la evacuación, la gestión de incidentes cibernéticos, la restauración de datos, etc.
- **Protocolos de comunicación:** Define cómo se comunicarán los miembros del equipo entre sí y cómo se informará a las partes interesadas externas (clientes, proveedores, autoridades).

6. Desarrollar un sistema de monitoreo y alerta

- **Monitoreo continuo:** Implementa herramientas o sistemas para monitorear los riesgos potenciales. Por ejemplo, sistemas de monitoreo de ciberseguridad o de clima en caso de desastres naturales.

- **Alertas tempranas:** Establece un sistema de alerta temprana para que los equipos estén al tanto de cualquier amenaza inminente y puedan actuar rápidamente.

7. Pruebas y simulacros

- **Pruebas regulares:** Realiza simulacros y pruebas del plan de contingencia para asegurarte de que todos los miembros del equipo sepan qué hacer en caso de emergencia.
- **Evaluación y ajustes:** Después de cada simulacro, evalúa qué funcionó bien y qué se puede mejorar. Ajusta el plan según sea necesario.

8. Documentar el plan

- **Documentación clara:** El plan debe estar documentado de manera clara y accesible para todas las personas involucradas.
- **Versiones y actualizaciones:** Mantén una versión actualizada del plan y distribúyela a todos los involucrados. Asegúrate de revisar el plan de forma periódica.

9. Comunicación post-crisis

- **Gestión de la reputación:** Después de una crisis, es crucial gestionar las comunicaciones con las partes interesadas para mantener la confianza. Un plan de comunicación post-crisis debe incluir mensajes clave para los empleados, clientes, proveedores y medios de comunicación.

Ejemplos:

Riesgo identificado: **Falla en el sistema informático**

1. Estrategia de **prevención**:
 - o Asegurar que los sistemas de respaldo estén operativos.
 - o Capacitar a los empleados en medidas básicas de seguridad cibernética.
2. Estrategia de **mitigación**:
 - o Tener un proveedor alternativo de servicios en caso de que el proveedor principal falle.
 - o Asegurar que se realicen copias de seguridad diarias.
3. Estrategia de **recuperación**:
 - o Recurrir a los backups para restaurar los sistemas.
 - o Asignar personal específico para la restauración de sistemas en caso de fallo.
4. Rol de las personas:
 - o Director de IT: Encargado de coordinar la recuperación del sistema.
 - o Equipo de comunicaciones: Encargado de informar a los clientes sobre el incidente.
5. Procedimiento de acción:
 - o Paso 1: Detectar el problema.
 - o Paso 2: Activar el equipo de contingencia.
 - o Paso 3: Restaurar desde el backup.
 - o Paso 4: Informar a los clientes y empleados.
6. Prueba de contingencia:
 - o Realizar simulacros mensuales de recuperación de datos.

Riesgo identificado: **Inundación**

Objetivo:

Minimizar los daños materiales y proteger la seguridad de los empleados y activos en caso de inundación.

Estrategias de respuesta:

- **Prevención:**
 - o Identificar áreas vulnerables en las instalaciones (sótanos, áreas bajas) y tomar medidas preventivas, como el uso de barreras de agua.
 - o Mantener sistemas de drenaje y bombas en buen estado de funcionamiento.
 - o Asegurar que los equipos tecnológicos críticos estén ubicados en niveles elevados o bien protegidos.
- **Mitigación:**
 - o Realizar evacuaciones de áreas específicas si se pronostica una inundación cercana.
 - o Evitar almacenar documentos o equipos importantes en zonas propensas a inundarse.
 - o Contratar servicios de mantenimiento para desagües y sistemas hidráulicos.
- **Recuperación:**
 - o Tener un equipo responsable de revisar las instalaciones después de la inundación para evaluar daños y decidir qué áreas se deben cerrar temporalmente.
 - o Asegurar los servicios de restauración de datos si la inundación afecta los sistemas informáticos.
 - o Establecer un plan para reubicar personal a instalaciones temporales si la sede está inoperativa.

Roles y responsabilidades:

- **Coordinador de emergencia:** Monitorear las alertas meteorológicas y activar el plan de emergencia.
- **Equipo de seguridad:** Encargados de evacuar a las personas y garantizar su seguridad.
- **Equipo de IT:** Verificar los sistemas de respaldo de datos y la operatividad de la infraestructura tecnológica.

Procedimiento:

1. Monitorear las alertas meteorológicas locales.
2. Informar al personal de la amenaza de inundación.
3. Activar procedimientos de evacuación si se requiere.
4. Implementar las barreras de protección en zonas vulnerables.
5. Evacuar a las personas hacia áreas seguras.
6. Restaurar las operaciones tan pronto como las condiciones lo permitan.

Riesgo identificado: **Incendio**

Objetivo:

Proteger a las personas y minimizar los daños materiales y operativos derivados de un incendio.

Estrategias de respuesta:

- **Prevención:**
 - o Realizar revisiones periódicas de las instalaciones eléctricas y del sistema de calefacción.
 - o Implementar medidas de seguridad como extintores, rociadores automáticos y alarmas de incendios en lugares clave.
 - o Capacitar al personal en procedimientos de evacuación y el uso de extintores.
- **Mitigación:**
 - o Asegurar una evacuación rápida y ordenada de todo el personal, incluyendo la capacitación sobre rutas de escape.
 - o Proporcionar refugios temporales si el edificio queda dañado, pero las operaciones pueden continuar en otro lugar.
 - o Tener un protocolo claro sobre qué hacer si hay fuego en áreas específicas (servidores, cocinas, laboratorios, etc.).
- **Recuperación:**
 - o Inspeccionar el edificio y los equipos antes de permitir el retorno del personal.
 - o Restaurar los datos perdidos a través de copias de seguridad, si es necesario.
 - o Reevaluar los procedimientos y hacer ajustes en el plan.

Roles y responsabilidades:

- **Líder de seguridad:** Coordina la evacuación y verifica que todos los sistemas de seguridad estén en funcionamiento.
- **Equipo de evacuación:** Encargado de guiar al personal a través de las rutas de escape.
- **Equipo de IT:** Realiza un análisis de daños a la infraestructura tecnológica y recupera datos de los respaldos si es necesario.

Procedimiento:

1. Activar la alarma de incendio.
2. Evacuar a todos los empleados siguiendo las rutas de escape designadas.
3. Evitar el uso de ascensores durante la evacuación.
4. Llamar a los servicios de emergencia (bomberos).
5. Evaluar los daños después del incendio y activar el plan de recuperación.

Riesgo identificado: **Ataque informático**

Objetivo:

Proteger los sistemas de información y datos sensibles contra ataques cibernéticos, como el ransomware o el robo de datos, y garantizar la continuidad operativa.

Estrategias de respuesta:

- **Prevención:**
 - o Implementar medidas de seguridad como firewalls, antivirus, cifrado de datos y autenticación multifactor.
 - o Realizar auditorías de seguridad regulares y parches de actualización en todos los sistemas.
 - o Capacitar a los empleados para reconocer ataques de phishing y otras amenazas cibernéticas.
- **Mitigación:**
 - o Desconectar los sistemas afectados para evitar que el ataque se propague.
 - o Notificar a los equipos de TI y seguridad informática inmediatamente.
 - o Mantener listas de contactos de emergencia con proveedores de seguridad y expertos en ciberseguridad.
- **Recuperación:**
 - o Restaurar los sistemas afectados desde copias de seguridad seguras.
 - o Asegurar que la información comprometida se proteja adecuadamente y tomar medidas legales si es necesario.
 - o Revisar los sistemas de seguridad para evitar que el ataque se repita y mejorar las políticas de seguridad interna.

Roles y responsabilidades:

- **Director de TI:** Coordina la respuesta a un ataque cibernético, incluyendo la desconexión de sistemas afectados y la restauración de datos.
- **Equipo de comunicaciones:** Mantiene informados a los empleados y clientes sobre el incidente y sus consecuencias.
- **Equipo legal:** Asesora sobre las implicaciones legales del ataque, como el robo de datos y las regulaciones de protección de datos.

Procedimiento:

1. Identificar el tipo de ataque (ransomware, DDoS, robo de datos, etc.).
2. Desconectar los sistemas afectados de la red.
3. Informar al equipo de TI y a la alta dirección.
4. Notificar a las autoridades, si es necesario, especialmente en casos de robo de datos sensibles.
5. Restaurar sistemas y datos desde copias de seguridad confiables.
6. Revisar el sistema para detectar posibles vulnerabilidades y prevenir futuros ataques.
7. Comunicar a los clientes y empleados sobre los efectos y las medidas tomadas.